

# Segurança da Informação

## Revisão para o ENADE 2026

Fundamentos, criptografia, identidade, ataques e LGPD


**Integrantes SQUAD 4:**

- Enrico Nalini Genaro
- Giovani Maia Tirapani
- Giovanna Santos Silva
- Murilo Vinicius de Faveri
- Rafael Platero Brandani
- Thais Gabriel


Ciência da Computação
Tópicos Avançados
**23/09/2026**

USCS
UNIVERSIDADE DE SÃO CAETANO DO SUL

## Conteúdo da Aula

1. Contextualização e objetivos
2. Fundamentos da Segurança da Informação
3. Criptografia e proteção dos dados
4. Identidade, controle de acesso e ataques
5. LGPD, privacidade e ética
6. Questões no estilo ENADE
7. Revisão final

## Objetivos da Aula

Ao final da aula, você deverá ser capaz de:

- Reconhecer os princípios da Segurança da Informação;
- Diferenciar ameaça, vulnerabilidade, risco e incidente;
- Comparar os principais mecanismos criptográficos;
- Explicar autenticação, autorização e MFA;
- Identificar ataques e controles adequados;
- Aplicar conceitos da LGPD em situações práticas.

USCS
UNIVERSIDADE DE SÃO CAETANO DO SUL

# Princípios da Segurança da Informação

| Princípio | Pergunta Principal |
|---|---|
| Confidencialidade | Somente pessoas autorizadas acessam? |
| Integridade | Os dados permanecem corretos? |
| Disponibilidade | O recurso está acessível quando necessário? |
| Autenticidade | A identidade e a origem são verdadeiras? |
| Não repúdio | Existe evidência da ação realizada? |

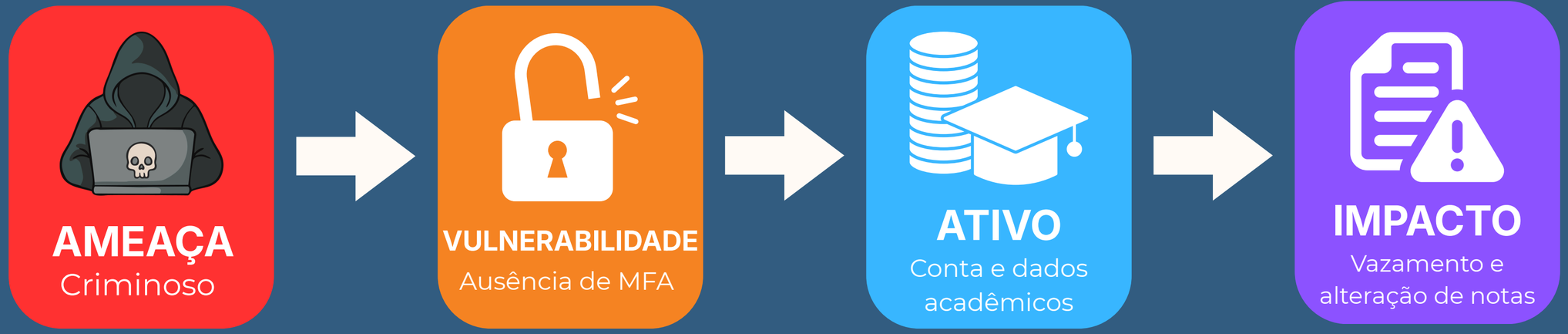


**Exemplo prático**

Em um prontuário médico:

- Um funcionário sem autorização consulta o prontuário: falha de confidencialidade;
- O diagnóstico é alterado: falha de integridade;
- O hospital não consegue abrir o sistema: falha de disponibilidade;
- Um site falso se passa pelo portal do hospital: falha de autenticidade;
- Um médico nega ter assinado uma receita digital: questão de não repúdio.

# Formação de um risco




**CONTROLES: MFA, alertas, logs e recuperação**

- **Ativo:** algo que possui valor
- **Ameaça:** algo capaz de causar dano
- **Vulnerabilidade:** fraqueza que pode ser explorada
- **Incidente:** ocorrência que compromete a segurança
- **Controle:** medida que reduz o risco

# QUESTÃO 1

Um hospital de grande porte modernizou sua infraestrutura de tecnologia implementando um sistema de Prontuário Eletrônico do Paciente (PEP). A arquitetura de segurança da informação adotada engloba controle de acesso baseado em papéis (RBAC), criptografia simétrica (AES-256) para dados em repouso, assinaturas digitais baseadas em infraestrutura de chave pública (ICP) com certificados X.509 para prescrições, além de replicação de servidores para alta disponibilidade.

Durante uma auditoria de conformidade com a ISO/IEC 27001 e a LGPD, foram registradas as seguintes ocorrências:

**I.** Um técnico de enfermagem utilizou temporariamente as credenciais de acesso de um médico plantonista — obtidas por negligência na guarda de senha — para visualizar históricos clínicos de pacientes alocados em alas sob a responsabilidade de outra equipe, sem que o sistema disparasse alertas de desvio de perfil, embora o acesso tenha sido registrado em log.
**II.** Um ataque de negação de serviço distribuído (DDoS) exauriu os recursos da infraestrutura de borda, tornando o PEP inacessível por 45 minutos nas unidades de terapia intensiva e violando o Acordo de Nível de Serviço (SLA) de continuidade operacional.
**III.** Uma prescrição digital foi assinada com a chave privada de um médico, mas, devido a uma vulnerabilidade na função de hash subjacente (geradora de colisões), um atacante conseguiu alterar o conteúdo do arquivo prescrito sem que a verificação da assinatura digital pela farmácia apontasse falha.
**IV.** Um administrador de banco de dados mal-intencionado alterou diretamente os registros de um diagnóstico sensível na tabela transacional; contudo, visto que o armazenamento utilizava criptografia simétrica convencional (AES-256) voltada exclusivamente à confidencialidade, a adulteração passou despercebida pelos mecanismos de verificação de integridade.

Considerando os conceitos fundamentais da Segurança da Informação, avalie as afirmativas a seguir:

**I.** A ocorrência I evidencia uma falha grave de *confidencialidade* e de controle de acesso, comprometendo também a confiabilidade da autoria devido ao compartilhamento inadequado de credenciais.
**II.** A ocorrência II caracteriza uma violação direta da propriedade de *disponibilidade*, essencial em ambientes críticos de saúde onde a demora na informação pode colocar vidas em risco.
**III.** A ocorrência III ilustra um comprometimento da *integridade, demonstrando que a fragilidade na função matemática de *hash que alimenta a assinatura digital pode quebrar a garantia de imutabilidade do documento.
**IV.** A ocorrência IV reforça que cifras simétricas tradicionais focadas na *confidencialidade* (como o AES em modos básicos) não garantem, por si sós, a *integridade* dos dados contra modificações não autorizadas.

É correto o que se afirma em:
**A)** Apenas I e II.
**B)** Apenas III e IV.
**C)** Apenas I, II e III.
**D)** Apenas II, III e IV.
**E)** I, II, III e IV.

# QUESTÃO 1

**Gabarito Comentado:**

**Alternativa correta: E (I, II, III e IV)**

**Afirmação I (Verdadeira):** O acesso não autorizado a dados clínicos por um colaborador sem privilégios para tal viola diretamente a **confidencialidade**. O uso de credenciais de terceiros corrompe a premissa de autenticidade e não-repúdio, pois a auditoria não conseguirá vincular a ação ao agente real.

**Afirmação II (Verdadeira):** A indisponibilidade do sistema de prontuários por 45 minutos em uma UTI caracteriza uma quebra flagrante da **disponibilidade**, impedindo o acesso à informação no momento em que ela é criticamente necessária.

**Afirmação III (Verdadeira):** A assinatura digital depende de um hash seguro. Se o algoritmo sofrer de vulnerabilidades severas (como a geração de colisões), um atacante consegue manipular o texto original mantendo o mesmo resumo criptográfico, quebrando a **integridade** do processo.

**Afirmação IV (Verdadeira):** A criptografia simétrica padrão (como o AES em modo CBC ou ECB) protege a confidencialidade (mantém os dados ilegíveis para quem não tem a chave), mas não previne modificações maliciosas nos dados criptografados se não houver mecanismos integrados de autenticação de mensagens ou hashing (como o AES-GCM ou uso de HMAC).

# Criptografia e integridade

- **Criptografia simétrica:** utiliza a mesma chave secreta para criptografar e descriptografar os dados.
- **Criptografia assimétrica:** utiliza um par de chaves, sendo uma pública e outra privada.
- **Hash:** transforma os dados em um resumo de tamanho fixo, usado para verificar sua integridade.
- **HMAC:** combina uma função hash com uma chave secreta para verificar a integridade e a autenticidade dos dados.

| Mecanismo | Principal Finalidade |
|---|---|
| Criptografia simétrica | Confidencialidade com chave secreta |
| Criptografia assimétrica | Uso de chave pública e privada |
| Hash | Verificação de integridade |
| HMAC | Integridade e autenticidade |
| Assinatura digital | Autenticidade, integridade e não repúdio |
| Certificado digital | Associação entre identidade e chave pública |

# Proteção de um documento digital

**Situação:**

Uma empresa envia um contrato confidencial pela internet.

**Necessidades:**

- Impedir a leitura por terceiros;
- Detectar alterações;
- Comprovar quem assinou;
- Confirmar a identidade vinculada à chave pública.

| Necessidade | Solução |
|---|---|
| Ocultar o conteúdo | Criptografia |
| Detectar alteração | Hash |
| Comprovar autoria | Assinatura digital |
| Validar a chave pública | Certificado digital |



# QUESTÃO 2

Um grande conglomerado hospitalar está estruturando sua nova plataforma digital de telemedicina e gestão de prontuários eletrônicos em nuvem. A arquitetura exige que o sistema atenda simultaneamente a três pilares rigorosos:

**1. Dados em Repouso:** Armazenamento massivo de exames de imagem de alta resolução e prontuários volumosos em bancos de dados relacionais, exigindo alta performance de leitura/escrita e proteção robusta contra vazamentos.

**2. Dados em Trânsito:** Comunicação síncrona, de baixíssima latência e criptografada entre os aplicativos móveis dos médicos em campo e a infraestrutura central de servidores via internet aberta.

**3. Integridade e Autenticidade Transacional:** Assinatura digital de prescrições médicas de alta complexidade com validade jurídica perante órgãos reguladores (ICP-Brasil).

A equipe de arquitetura de segurança da informação foi encarregada de selecionar os mecanismos criptográficos ideais para cumprir os requisitos de desempenho, confidencialidade, integridade e conformidade regulatória.

Considerando as propriedades matemáticas e operacionais dos algoritmos e protocolos de segurança, qual é a combinação de mecanismos técnica e arquiteturalmente mais adequada?

**A)** Empregar criptografia assimétrica (RSA com chaves de 4096 bits) tanto para o armazenamento em repouso quanto para o tráfego de rede, visto que o uso exclusivo de chaves públicas e privadas elimina a necessidade de gestão complexa de chaves simétricas e garante máxima segurança matemática.

**B)** Utilizar criptografia simétrica de bloco (como o AES-256 em modo autenticado GCM) para os dados em repouso e o protocolo TLS moderno para os dados em trânsito (utilizando criptografia assimétrica apenas no handshake para autenticação e troca segura de chaves, e simétrica para o fluxo contínuo de dados), garantindo desempenho, confidencialidade e integridade integradas.

**C)** Aplicar funções criptográficas de dispersão unidirecional (como o SHA-3/512) para cifrar e proteger o conteúdo dos dados tanto em repouso quanto em trânsito, aproveitando a propriedade de irreversibilidade do hash para impedir qualquer visualização indevida por terceiros.

**D)** Adotar algoritmos de derivação de chaves e salting (como Argon2id) em conjunto com criptografia assimétrica pura para todo o tráfego de rede, dispensando o uso de protocolos de sessão para simplificar a camada de transporte e evitar sobrecarga de processamento.

**E)** Utilizar exclusivamente assinaturas digitais baseadas em curvas elípticas (ECDSA) para a cifra de grandes volumes de dados em repouso e em trânsito, pois a eficiência matemática das curvas elípticas substitui com vantagens o desempenho do AES em qualquer cenário de armazenamento.

# QUESTÃO 2

**Gabarito Comentado:**

**Alternativa correta: B**

**Análise da Alternativa B (Correta):** Para grandes volumes de dados em repouso, cifras simétricas como o AES-256 (especialmente em modos autenticados como o GCM, que une confidencialidade e integridade) oferecem o balanceamento ideal entre desempenho computacional e segurança impenetrável. Para os dados em trânsito, o protocolo TLS (Transport Layer Security) emprega uma arquitetura híbrida perfeita: usa criptografia assimétrica (RSA ou ECC) na fase inicial (handshake) para autenticar as partes e negociar uma chave secreta, e transiciona para criptografia simétrica para o transporte veloz de todo o restante da sessão.
**Análise da Alternativa A (Incorreta):** A criptografia assimétrica (como o RSA) realiza operações matemáticas altamente complexas e custosas para a CPU. Utilizá-la para cifrar grandes volumes de dados (gigabytes de prontuários e imagens) geraria um gargalo de desempenho inaceitável no banco de dados e na rede.
**Análise da Alternativa C (Incorretaconfundida):** Funções de hash (como o SHA-3) *não cifram dados. Elas são unidirecionais e servem estritamente para calcular resumos de integridade, sendo matematicamente impossível "desfazer" um *hash para recuperar o texto original.
**Análise da Alternativa D (Incorreta):** Técnicas de derivação de chaves e salting (como Argon2id) são projetadas especificamente para o armazenamento seguro de senhas (protegendo contra ataques de força bruta e tabelas rainbow), e não para a cifragem de grandes fluxos de dados ou arquivos de prontuários.
**Análise da Alternativa E (Incorreta):** Embora curvas elípticas (ECDSA/ECC) sejam extremamente eficientes para assinaturas e trocas de chaves com tamanhos menores, elas não são algoritmos de cifra simétrica projetados para substituir o AES na cifragem em massa de dados volumosos em disco ou em canais de transporte contínuo.

# Da identidade à permissão

| Etapa | Pergunta | Exemplo |
|---|---|---|
| Identificação | Quem você afirma ser? | E-mail |
| Autenticação | Como prova sua identidade? | Senha e Token |
| Autorização | O que pode fazer? | Alterar somente suas turmas |
| Auditoria | O que fez no sistema? | Registro no log |

**Destaques inferiores:**

- MFA;
- Mínimo privilégio;
- RBAC;
- Separação de funções.



# Ataques frequentes e respectivas defesas

| Ataque | O que acontece | Controle relacionado |
|---|---|---|
| Phishing | Roubo de credenciais | MFA, filtros e treinamento |
| MITM | Interceptação da comunicação | TLS e validação de certificado |
| ARP spoofing | Falsificação da relação IP e MAC | Proteção e segmentação da rede |
| SQL Injection | Entrada altera comandos SQL | Consultas parametrizadas |
| Ransomware | Dados ficam inacessíveis | Backup isolado e restauração |
| Acesso indevido em API | Usuário acessa recurso de outro | Autorização no servidor |

**Exemplo prático:**

Uma API utiliza o endereço:

```
/api/alunos/105/documentos
```

O usuário troca 105 por 106 e consegue abrir o documento de outro aluno.

# QUESTÃO 3

Em uma rede corporativa legada, o setor de segurança da informação identificou vulnerabilidades críticas na Camada de Enlace (Camada 2 do modelo OSI), permitindo que agentes maliciosos executem ataques de envenenamento de cache para desviar o fluxo de pacotes de dados. Para mitigar o impacto dessa exposição sem paralisar as operações, a equipe arquitetou contramedidas baseadas em criptografia de sessão e validação estrita de certificados.

Considerando esse cenário técnico de defesa em profundidade e os protocolos envolvidos, avalie as asserções a seguir e a relação proposta entre elas:

I. A implementação rigorosa do protocolo TLS (Transport Layer Security) com validação mandatória de certificados e políticas de HSTS (HTTP Strict Transport Security) protege a confidencialidade e a integridade dos dados trafegados contra interceptações ativas, mesmo que o atacante tenha obtido sucesso em redirecionar o tráfego da rede local, embora o TLS não corrija a falha estrutural do protocolo ARP.

**PORQUE**

II. O protocolo ARP (Address Resolution Protocol) carece de mecanismos nativos de autenticação, integridade ou criptografia na Camada 2, aceitando cegamente respostas e pacotes Gratuitous ARP não solicitados, o que corrompe as tabelas de mapeamento IP-MAC dos dispositivos e viabiliza a criação furtiva de cenários de Homem no Meio (Man-in-the-Middle).

A respeito dessas asserções, assinale a opção correta:

A) As asserções I e II são proposições verdadeiras, e a II é uma justificativa correta da I.
B) As asserções I e II são proposições verdadeiras, mas a II não é uma justificativa correta da I.
C) A asserção I é uma proposição verdadeira, e a II é uma proposição falsa.
D) A asserção I é uma proposição falsa, e a II é uma proposição verdadeira.
E) As asserções I e II são proposições falsas.

# QUESTÃO 3

**Gabarito Comentado:**

**A alternativa correta é a A: as duas asserções são verdadeiras, e a II justifica corretamente a I.**

**Análise da Asserção I (Verdadeira):** O uso correto do TLS garante a criptografia de ponta a ponta (payload) e a autenticidade do servidor por meio de certificados confiáveis. Isso significa que, mesmo que um atacante consiga executar um ARP Spoofing e desviar os pacotes físicos para o seu próprio computador, ele verá apenas dados cifrados ilegíveis (protegendo a confidencialidade e a integridade), demonstrando uma aplicação clássica de defesa em profundidade. O TLS protege a aplicação, mas não conserta o protocolo de rede subjacente.

**Análise da Asserção II (Verdadeira):** O protocolo ARP foi projetado em uma época em que a segurança física e a confiança na rede local eram pressupostos. Ele não possui autenticação criptográfica, permitindo que qualquer máquina envie pacotes falsos (ARP Spoofing/Poisoning) e engane roteadores e hosts sobre quem possui determinado endereço IP, estruturando o caminho para ataques MitM.

**Relação de Justificativa (Correta):** A fragilidade estrutural do ARP descrita na II (a incapacidade da rede local de garantir a integridade dos endereçamentos de camada 2) é exatamente a motivação lógica e técnica pela qual a contramedida descrita na I (a criptografia de transporte TLS) se torna indispensável para resgatar a segurança da informação em camadas superiores.

# Proteção de dados pessoais

| Conceito | Exemplo |
|---|---|
| Dado pessoal | Nome, CPF, telefone e e-mail |
| Dado pessoal sensível | Biometria, saúde, religião e origem racial |
| Anonimização | Associação razoável com a pessoa deixa de ser possível |
| Pseudominização | Associação depende de informação adicional |
| Titular | Pessoa a quem os dados se referem |
| Tratamento | Coleta, uso, armazenamento, compartilhamento ou eliminação |



**Princípios em destaque:**

- Finalidade;
- Necessidade;
- Transparência;
- Segurança;
- Prevenção.

# Biometria para controle de presença

**Situação:**
| Uma universidade pretende usar reconhecimento facial para registrar presença.

**Questões para análise:**

- A coleta é realmente necessária?
- Existe uma alternativa menos invasiva?
- Qual é a finalidade?
- Por quanto tempo os dados serão mantidos?
- Como a biometria será protegida?
- O estudante poderá contestar erros?
- O sistema foi avaliado quanto a vieses?



**Atenção:**

- Consentimento não é a única base legal;
- Consentimento não autoriza qualquer finalidade;
- Pseudonimização não elimina todos os riscos;
- A ANPD não modifica leis;
- Dados públicos continuam sujeitos a regras de tratamento;
- Coletar mais dados do que o necessário contraria a minimização.

# QUESTÃO 4

Uma holding corporativa do setor de saúde e biotecnologia está estruturando um ambicioso projeto de Big Data e inteligência artificial para o desenvolvimento de modelos preditivos voltados a diagnósticos precoces. Para mitigar riscos regulatórios perante a Autoridade Nacional de Proteção de Dados (ANPD) e garantir a conformidade com a Lei Geral de Proteção de Dados (LGPD - Lei nº 13.709/2018), o comitê de governança e conformidade jurídica foi acionado para orientar a equipe de engenharia de dados sobre o ciclo de vida, a taxonomia e as técnicas de tratamento das informações dos pacientes.

Considerando os conceitos dogmáticos e legais estabelecidos pela LGPD, avalie as afirmativas a seguir:

**I.** Dados pessoais relativos à saúde humana e dados biométricos vinculados a uma pessoa natural identificada ou identificável recebem a qualificação jurídica de **dados pessoais sensíveis**, exigindo, por regra geral, o cumprimento de hipóteses legais mais restritivas para o seu tratamento e vedando o seu uso discriminatório.
**II.** A técnica de **pseudonimização** consiste no tratamento por meio do qual um dado perde a possibilidade de associação, direta ou indireta, a um indivíduo, fazendo com que, imediatamente após a sua aplicação, o conjunto de dados deixe irrevogavelmente de ser considerado dado pessoal para todos os efeitos legais da LGPD.
**III.** Para que se configure a **anonimização** efetiva sob a ótica legal da LGPD, o processo deve ser irreversível, considerando o uso de meios técnicos disponíveis e razoáveis na ocasião do tratamento; caso a associação com a pessoa possa ser restabelecida por meios lógicos ou tecnológicos viáveis, o dado permanece juridicamente classificado como pessoal.
**IV.** O conceito legal de **tratamento** de dados pessoais possui acepção ampla, abrangendo qualquer operação realizada com dados pessoais, tais como a coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação ou modificação.

É correto o que se afirma em:
**A)** Apenas I e II.
**B)** Apenas II e III.
**C)** Apenas I e IV.
**D)** Apenas II, III e IV.
**E)** Apenas I, III e IV.

# QUESTÃO 4

**Gabarito Comentado:**

**A alternativa correta é a E, pois as afirmações I, III e IV estão corretas.**

**Afirmação I (Verdadeira):** Conforme o art. 5º, inciso II, da LGPD, dados sobre a saúde e dados biométricos quando vinculados a uma pessoa natural são expressamente classificados como **dados pessoais sensíveis**, atraindo maiores exigências legais e restrições para o seu tratamento (art. 11).
**Afirmação II (Falsa):** A pseudonimização **não** elimina definitivamente a natureza de dado pessoal. Na pseudonimização, os identificadores diretos são mascarados ou substituídos, mas a reidentificação ainda é possível por meio de informações adicionais mantidas em separado e de forma controlada. Portanto, **dados pseudonimizados continuam sendo considerados dados pessoais** perante a LGPD.
**Afirmação III (Verdadeira):** O art. 12 da LGPD estabelece que o dado anonimizado não será considerado dado pessoal para os fins da lei, salvo quando o processo de anonimização puder ser revertido com esforço desproporcional ou quando forem utilizados meios razoáveis (state of the art) para a reidentificação. Se a reidentificação for viável por meios razoáveis, o dado continua sujeito à LGPD.
**Afirmação IV (Verdadeira):** O art. 5º, inciso X, da LGPD define "tratamento" de forma extremamente abrangente, cobrindo absolutamente todo o ciclo de vida da informação dentro de uma organização, desde a sua coleta inicial até a sua eliminação definitiva.

# Resumo

1. **CIA:** confidencialidade, integridade e disponibilidade.
2. **Risco:** ameaça explora vulnerabilidade e afeta um ativo.
3. **Criptografia:** cifragem oculta, hash detecta alterações.
4. **Acesso:** identificar, autenticar, autorizar e auditar.
5. **Ataques:** cada problema exige um controle adequado.
6. **LGPD:** finalidade, necessidade, proteção e direitos do titular.



# Alguma Pergunta?

SQUAD 4

# Agradecemos a Atenção!